

Common GRC Frameworks, Standards, and Regulations

- **NIST Cybersecurity Framework (NIST CSF)** – Provides a structured approach for identifying, protecting, detecting, responding to, and recovering from cybersecurity risks.
- **NIST SP 800-53** – Provides a catalog of security and privacy controls for information systems and organizations.
- **CIS Controls** – A prioritized set of cybersecurity safeguards organizations can use to reduce common security risks.
- **PCI DSS** – Security requirements designed to protect payment card information and organizations that store, process, or transmit cardholder data.
- **ISO/IEC 27001** – An international standard for establishing and maintaining an information security management system (ISMS).
- **SOC 2** – A framework for evaluating controls related to security, availability, processing integrity, confidentiality, and privacy.
- **HIPAA** – U.S. requirements for protecting certain health information and maintaining appropriate security and privacy safeguards.
- **GDPR** – European Union regulation focused on protecting personal data and privacy.
- **SOX (Sarbanes-Oxley Act)** – U.S. law that includes requirements related to financial reporting and internal controls for applicable organizations.
- **FISMA** – U.S. federal requirements for managing information security and protecting government information systems.
- **FedRAMP** – A U.S. government program for assessing and authorizing cloud services used by federal agencies.

GRC is important because it helps organizations manage cybersecurity in a consistent and organized way. Without clear policies, standards, and procedures, employees and security teams may handle security issues differently, which can create gaps and increase risk. GRC gives an organization a structured way to define security expectations and make sure those expectations are being followed.

GRC also helps organizations identify and manage risks before they become serious security incidents. By assessing threats and vulnerabilities, organizations can prioritize which problems need the most attention and determine what security controls should be put in place. This allows organizations to focus their resources on the risks that could have the greatest impact.

Compliance is another important part of GRC because organizations may need to meet legal, regulatory, industry, or contractual requirements. Frameworks and standards such as NIST CSF, CIS Controls, PCI DSS, and ISO 27001 can help organizations establish security practices and demonstrate that appropriate controls are in place. Overall, GRC helps connect cybersecurity with business operations by creating accountability, reducing risk, and providing a clear framework for protecting systems and information.

